

Documentação técnica da plataforma Aurora (saúde mental/bem-estar ocupacional).

Índice

- Autenticação e RBAC
- Referência de API
- Comportamentos e limitações conhecidas

Arquitetura (visão geral)

```
[Navegador] — SPA (React/Vite, Vercel) —HTTPS+Bearer→ [aurora-api] —> [inTable (datastore)]
      |
      |— login OIDC —> [Keycloak / inProfile]
```

- **Frontend:** SPA (React + Vite) hospedada na **Vercel** (com Vercel Deployment Protection no sandbox).
- **Backend:** `aurora-api` (REST; formato de erro padrão NestJS: `{message,error,statusCode}`).
- **Integração de dados:** `inTable` (tabelas do tenant) — chave de API por tenant.
- **Autenticação:** **Keycloak** (realm `stg-inprofile`) via OIDC, com broker Microsoft (inbot).

Ambientes

Ambiente	URL
App (sandbox)	<code>https://sandbox-inbot-aurora.vercel.app</code>
API (sandbox)	<code>https://aurora-api-sandbox.inbot.com.br</code>
Keycloak	<code>https://keycloak.staging.e-auth.cloud/realms/stg-inprofile</code> (client <code>app-admin</code>)

Rotas do frontend

Rota	Tela
<code>/</code>	Home / Painel
<code>/colaboradores</code>	Gestão de Colaboradores
<code>/pedidos</code>	Pedidos de Protocolo
<code>/adesao</code>	Adesão e Engajamento
<code>/metricas-ia</code>	Métricas da IA
<code>/casos-graves</code>	Casos Graves
<code>/relatorios/individuais?protocolo=</code>	Relatórios Individuais (BAI/BHS/BDI/BSS)
<code>/relatorios/copsoq</code>	Relatório COPSOQ
<code>/relatorios/consolidado</code>	Resultados Consolidados
<code>/auditoria</code>	Auditoria do Sistema
<code>/configuracoes</code>	Configurações

⚠ Rotas de relatório (`/relatorios/*`) dependem de navegação client-side — ver comportamentos.

Autenticação e RBAC

Fluxo de autenticação

- 1. A SPA redireciona para o **Keycloak** (realms/stg-inprofile , client_id=app-admin).
- 2. A tela do Keycloak oferece login **federado via broker Microsoft ("inbot")**. Usuários federados (@inbot.com.br) **devem** usar o broker (não há senha local).
- 3. Após o SSO, a SPA obtém um **token Bearer (JWT)** e o renova em runtime (refresh silencioso via cookie de sessão Keycloak). O token **não é persistido** em localStorage.
- 4. Toda chamada à aurora-api envia o header **Authorization: Bearer <jwt>**.

Sandbox: a app está atrás de **Vercel Deployment Protection** — sessões automatizadas precisam também dos cookies Vercel (_vercel_jwt).

Contexto do usuário — GET /me

```
{
  "sub": "...",
  "email": "renato.paulino@inbot.com.br",
  "nome": "...",
  "perfil": "direcao",
  "tenantId": "...",
  "capabilities": ["colaborador.read", "..."],
  "needs_provisioning": false
}
```

Permissões (capabilities)

O acesso é controlado por **capabilities** entregues no /me . Cada endpoint exige a sua.

Capability	Habilita
colaborador.read/create/update/delete/import	CRUD + importação de colaboradores
relatorio.individual.read	Relatórios BAI/BHS/BDI/BSS
relatorio.copsoq.read	Relatório COPSQ
relatorio.consolidado.read	Resultados Consolidados
relatorio.adesao.read	Adesão (/pedidos/lotes)
pedido.read/create	Pedidos (consulta/criação)
metricas-ia.read	Métricas da IA
caso-grave.read/update	Casos graves (consulta/tratativa)
kpi.read , kpi.casos-graves.read	Indicadores (dashboard/casos)
configuracao.read/visual.update/campos.update/provisioning.read	Configurações
auditoria.read	Auditoria

⚠ Há divergência conhecida: o perfil direcao possui auditoria.read , mas GET /auditoria retorna 403 (ver #688).

Referência de API

Base: `https://aurora-api-sandbox.inbot.com.br` · Auth: Authorization: Bearer <jwt> · Erros: { message, error, statusCode } .

Contexto

GET /me

Retorna o contexto/permisões do usuário. → { sub, email, nome, perfil, tenantId, capabilities[], needs_provisioning }

Colaboradores

GET /colaboradores

Query: page, limit (default 50), search (nome/e-mail), departamento . *(o filtro ativo está quebrado — ver #697; status / q / nome são ignorados.)*

→ { data: [{ id, nome, cpf, email, departamento, cargo, ativo, dataNascimento, telefone, genero, escolaridade, estadoCivil, ... }], page, limit, total }

POST /colaboradores

Body: { ativo, nome, cpf, email, dataNascimento (ISO yyyy-mm-dd), departamento, cargo, telefone } → 201 { id }

Erros: 400 {message:["cpf inválido"]}, ["email must be an email"], ["dataNascimento ...","must be a Date instance"] *(ver #493, #497)*.

PUT /colaboradores/:id

Body completo (mesmos campos do POST) → 204. 404 se o id não existir. *(PATCH e GET /colaboradores/:id → 404: não implementados.)*

DELETE /colaboradores/:id

→ 204. 404 se não existir.

POST /colaboradores/import

multipart/form-data, campo file (CSV). Header CSV:

nome,cpf,email,departamento,cargo,dataNascimento,telefone,escolaridade,estadoCivil,genero .

→ 201 { inserted, updated, errors } · 422 { message, erros: [{ linha, campo, motivo }] } .

Telas / Relatórios (somente leitura)

GET /screens/dashboard

→ { bemEstar, risco, balancaTrabalhoVida, casosGravesAbertos } (números; rótulos são calculados no front).

GET /screens/metricas-ia?periodo=7

→ { kpis: { interacoes, quantidadeUsuarios }, serie: [{ name, interacoes }] } (N pontos = dias do período). *(Sem campo de variação — ver #687.)*

GET /screens/relatorios/protocolo/{bai|bhs|bss|bdi}

→ { protocolo, periodo:{inicio,fim}, totalRespostas, mediaScore, distribuicao:[{nome,quantidade}], resultados:[{colaboradorId,nome,email,score,nivel,genero,faixaEtaria,escolaridade,areaTrabalho}], distribuicoesDemo:{...}, casosGravesPorDemo:{...}, perguntas:[{numero,descricao,mediaValor,nivelLabel}] }

⚠ BHS usa a chave perguntasBhs:[{numero,descricao,percentualCritico,severidade}] (ver #691).

GET /screens/relatorios/protocolo/copsoq

→ { periodo, totalJornadas, kpis:{ bemEstar:{valor,label}, risco:{valor,label}, balanca:{valor} }, distribuicoes:{...}, pontosFortes:[{dimensao,media,label,numQuestoes}], pontosAtencao:[...], riscoPorGrupos:{...} }

⚠ kpis.balanca vem sem label (ver #689).

GET /screens/relatorios/consolidado

→ { periodo:{inicio,fim}, taxaParticipacao:{participantes,total,percentual}, kpis:{bemEstar,risco,balanca}, distribuicoes:{niveisBai,niveisBhs}, casosGraves:[{nome,email,protocolos[]}], resultados:[{colaboradorId,nome,email,linhas[]}] } *(requisição sem ?periodo= .)*

Casos Graves

GET /screens/casos-graves?periodo=30

periodo: 7|30 (ou histórico). → { kpis:{total,abertos,emAndamento,concluidos,arquivados}, casos:[{id,colaborador,colaboradorId,tipo,nivel,detalhe,status,responsavel,dataAbertura,dataAtualizacao,score,comentarios[],timeline agrupados:[...]}]}

PATCH /casos-graves/:id/status

Body: { status } (Aberto|Em Andamento|Concluído|Arquivado) → 200 { id, status }. 422 {error:"Transição de status inválida", de, para} (máquina de estados).

POST /casos-graves/:id/comentarios

Body: { texto, autorNome, responsavelId } → 201 { id, casoGraveId, tipo:"comment", texto, autorNome, ... }.

Pedidos

GET /pedidos

Query: page, limit. → { data:[{id,protocolo,colaboradorEmail,status,criadoEm,atendidoEm,entrevistaId}], page, limit, total }

GET /pedidos/lotos → [{ protocolo, data, total, atendidos, percentual }]

GET /pedidos/adesao → [{ protocolo, total, atendidos, percentual }]

POST /pedidos (individual)

Body: { colaboradorId, protocolo } → 201 · 409 {message:"Já existe um pedido aberto de <P> para <colab>"} .*(validação de corpo vazio → 409/undefined; ver #701.)*

POST /pedidos/lote (em lote)

Body: { protocolo } → cria pedidos para **todos os colaboradores ativos** (ignora quem já tem pedido aberto). *(corpo inválido → 500; ver #701.)*

Configurações

GET /configuracoes

→ { botId, syncEnabled, intableApiKeyConfigured, visual:{logoBase64,corPrincipal}, datasources:[...], departamentos:[...], cargos:[...] }

GET /configuracoes/campos/uso → { departamentos:{<nome>:<count>}, cargos:{<nome>:<count>} }

GET /configuracoes/provisioning/status → { items:[{id,status,actionable}], tables:[{tableName,exists,active,rowCount,lastUpdated}] }

PATCH /configuracoes/visual — Body { logoBase64, corPrincipal } → 200

PATCH /configuracoes/departamentos — Body { departamentos:[] } → 200

PATCH /configuracoes/cargos — Body { cargos:[] } → 200

⚠ As escritas de configuração respondem 200 mas **não persistem** (ver #700).

Auditoria

GET /auditoria

Esperado: lista de eventos { "Data e Hora", "Usuário", "Ação", "Recurso", "Decisão" }. **Atual: 403** {message:"Acesso negado",...} mesmo com auditoria.read (ver #688).

Comportamentos e limitações conhecidas

Notas técnicas observadas (sandbox, 2026-06). Issues no repositório `in-bot/aurora`.

Consistência / dados

- **Escritas eventualmente consistentes:** após `POST /colaboradores` (201), o registro só fica operável/consultável após um tempo **não determinístico** (~3s a >75s). PUT/DELETE por id dão 404 até propagar. Planejar **retry/polling** em integrações.
- **Listagem capada em 50:** a tela de Colaboradores carrega só a 1ª página da API e pagina no client — esconde a maioria dos ativos (#698). A API suporta `?page=&limit=` corretamente.
- **Busca não indexa recém-criados:** `?search=` não retorna registros recém-inseridos por um tempo (#680).
- **Filtro `?ativo=`** retorna vazio para qualquer valor (#697).

Relatórios

- **Deep-link/refresh** em `/relatorios/individuais?protocolo=x` é ignorado (abre BAI); a troca de protocolo é por **clique na aba** (estado interno). `/relatorios/consolidado` redireciona para a Home no acesso direto — carregar via navegação client-side (#695).
- **Contrato BHS divergente:** usa `perguntasBhs` em vez de `perguntas` (#691).
- **kpis.balanca sem label** nos relatórios (#689); rótulo de distribuição fixo em "ANSIEDADE" (#696); gráficos barra vs. pizza/rosca divergem do protótipo (#692/#693).
- **Métricas IA:** a API não retorna dados de variação (% exibido é estático no front) (#687).

Escrita

- **Configuração no-op:** `PATCH /configuracoes/*` responde 200 sem persistir (#700).
- **Validação fraca em Pedidos:** `POST /pedidos {}` → 409 "undefined"; `POST /pedidos/lote {}` → 500 (deveria 400) (#701).
- **CPF:** a API valida dígito verificador (`POST` com CPF inválido → 400 "cpf inválido"); o front mostra erro genérico (#683). Importação rejeita CPF inválido com 422 (graceful).

Autenticação

- `GET /auditoria` → **403** apesar de o `/me` conceder `auditoria.read` ao perfil (#688).
- Token Bearer **não persistido**; renovação por refresh silencioso (cookie Keycloak). Integrações server-to-server devem usar fluxo próprio (service account/direct grant), não o `storageState` do browser.

Cobertura de testes (referência)

Suíte E2E + contratos de API em `tests/` (Playwright). Camada de API cobre relatórios, RBAC e CRUD de colaboradores/configuracoes/pedidos/tratativa. Telas rodam em modo serial. Ver PR #1.